

Nachmittag 5 – Respond

Tabletop: Ransomware bei der Muster Metallbau AG

Ein Incident-Response-Szenario in drei Phasen durchspielen

Dauer	60 Minuten (3 Phasen à ca. 15 Min. + 15 Min. Debriefing)
Arbeitsform	Gruppen à 4–5 Personen; jede Gruppe ist das „Krisenteam“ der Muster AG
Material	Dieses Arbeitsblatt; die Phasen-Informationen werden von der Workshop-Leitung nacheinander freigegeben – nicht vorblättern!
NIST-CSF-Bezug	Respond: RS.MA (Incident Management), RS.AN (Analyse), RS.CO (Kommunikation/Meldung), RS.MI (Eindämmung)

Lernziele

- Erstmassnahmen bei einem Sicherheitsvorfall strukturiert treffen (Eindämmen vor Aufklären vor Wiederherstellen).
- Rollen im Ernstfall besetzen und Entscheidungen unter Unsicherheit dokumentieren.
- Interne und externe Kommunikation (Mitarbeitende, Kunden, Behörden, Versicherung) bewusst steuern.

Ihre Rollen

Verteilen Sie zu Beginn diese Rollen in der Gruppe (bei 4 Personen übernimmt der Incident Commander zusätzlich die Dokumentation):

Rolle	Aufgabe
Incident Commander	Führt durch den Vorfall, trifft/verantwortet Entscheidungen, hält Kontakt zur GL (hier: übernimmt GL-Sicht gleich mit).
IT-Koordination	Schnittstelle zu TechPartner; bewertet technische Optionen, schlägt Eindämmungsmassnahmen vor.
Kommunikation	Formuliert Botschaften an Mitarbeitende, Kunden, ggf. Medien; führt die Kommunikationsmatrix.
Recht & Meldungen	Behält Meldepflichten, Versicherung und Vertragspflichten (Grosskunden!) im Blick.
Dokumentation	Führt das Entscheidungslog: Zeit, Entscheidung, Begründung, wer.

Phase 1 – Montag, 07:15 Uhr (ca. 15 Min.)

Lagemeldung 1

Die Sachbearbeiterin im Verkauf ruft an: „Das ERP startet nicht, und auf dem Dateiserver heissen alle Dateien plötzlich .locked. Auf dem Bildschirm ist eine Textdatei: ‚Your network has been encrypted. Contact us within 72 hours. Payment: 2 BTC.‘“ Drei weitere Mitarbeitende melden dasselbe. Die Produktion läuft noch, aber ohne ERP können keine Aufträge, Lieferscheine oder Rechnungen bearbeitet werden. Der Geschäftsführer ist bis Mittag im Ausland unterwegs, TechPartner hat noch nicht zurückgerufen.

Bearbeiten Sie als Krisenteam:

- Ihre fünf ersten Massnahmen, in Reihenfolge (Was zuerst? Was ausdrücklich noch nicht?).
- Was sagen Sie den Mitarbeitenden um 07:30 Uhr? (2–3 Sätze wörtlich formulieren)
- Erste Einträge ins Entscheidungslog.

Nr.	Massnahme	Wer macht es?
1		
2		
3		
4		
5		

Botschaft an die Mitarbeitenden (wörtlich):

Phase 2 – Montag, 10:30 Uhr (ca. 15 Min.)

Lagemeldung 2

TechPartner ist vor Ort und meldet: Auch das NAS-Backup im Serverraum ist verschlüsselt. Es existiert aber die neue Offsite-Kopie aus dem 90-Tage-Plan (Stand: gestern 22:00 Uhr, noch nie für einen vollständigen Restore genutzt). Gleichzeitig: Der Grosskunde Alpha AG ruft an – die Muster AG sollte heute Montagepläne liefern – und fragt, ob es „ein IT-Problem“ gebe. Ein Mitarbeiter fragt, ob er Kollegen in anderen Firmen „vorwarnen“ soll, und im Dorf kursiert bereits ein Gerücht über einen „Hackerangriff“.

Bearbeiten Sie als Krisenteam:

- Zahlen oder nicht zahlen? Sammeln Sie je zwei Argumente und treffen Sie eine begründete Entscheidung.
- Füllen Sie die Kommunikationsmatrix aus.
- Was braucht TechPartner jetzt von Ihnen, bevor mit dem Restore begonnen wird? (Mind. 2 Punkte)

Zielgruppe	Wann?	Über welchen Kanal?	Kernbotschaft (Stichworte)
Mitarbeitende			
Grosskunde Alpha AG			
Übrige Kunden			
Cyber-Versicherung			
Polizei / Behörden			

Entscheidung Lösegeld (mit Begründung):

Phase 3 – Dienstag, 09:00 Uhr (ca. 15 Min.)

Lagemeldung 3

Der Restore aus der Offsite-Kopie läuft an. Doch TechPartner findet in den Proxy-Logs Hinweise, dass in den Tagen vor der Verschlüsselung mehrere Gigabyte Daten an eine unbekannte Adresse abgeflossen sind – vermutlich Kundendaten und Offerten, möglicherweise auch Personaldaten (Double Extortion). Die Erpresser drohen inzwischen mit Veröffentlichung.

Bearbeiten Sie als Krisenteam:

- Was ändert der Datenabfluss rechtlich? Wen müssen Sie jetzt informieren bzw. wo Meldung erstatten – und in welcher Frist? (Denken Sie an Datenschutzrecht, Grosskunden-Verträge, Versicherung.)
- Ändert das Ihre Lösegeld-Entscheidung aus Phase 2? Warum (nicht)?
- Formulieren Sie die drei wichtigsten Punkte für die Information an die betroffenen Kunden.

Zum Abschluss – Ihre Notfallkarte (Hausaufgabe/Restzeit)

Füllen Sie auf Basis der Übung die Einseiten-Notfallkarte für die Muster AG (oder Ihr eigenes Unternehmen) aus:

Vorfall erkannt – wer wird zuerst angerufen (intern)?	
Externe Nummern (IT-Dienstleister, Versicherung, ggf. Behörde)	
Die drei ersten Sofortmassnahmen (immer gleich)	
Was niemals sofort tun?	
Wo liegt dieses Blatt im Ernstfall? (auch bei IT-Ausfall verfügbar!)	